QUESTION 7: IOC VS. IOA

DG Interns Hub Cybersecurity Internship – Week 5 Submission

Student Name: Gunjan **Track:** SOC Analyst Tier 1 **Topic:** Indicators of Compromise vs. Indicators of Attack

1. DEFINITIONS & CORE CONCEPTS

In threat detection, distinguishing between **Indicators of Compromise (IOC)** and **Indicators of Attack (IOA)** is essential for moving from reactive cleanup to real-time defense.

Indicator of Compromise (IOC): Reactive evidence of a past breach or infection. IOCs are static artifacts left behind on a host or network after malicious execution has already taken place (e.g., file hashes, IP addresses, malicious domains). **Indicator of Attack (IOA):** Proactive evidence of active adversary behavior and intent. IOAs focus on the tactics, techniques, and procedures (TTPs) being executed in real-time, regardless of the specific malware binary or tools used (e.g., execution of unauthorized code, lateral movement attempts).

2. COMPARISON MATRIX

Feature	Indicator of Compromise (IOC)	Indicator of Attack (IOA)
Primary Focus	**What** was executed (Static Artifacts).	**Why & How** it is acting (Adversary Intent/Behavior).
Time Orientation	**Reactive / Forensics:** Identifies systems that are already compromised.	**Proactive / Real-Time:** Detects and stops active attack progression.
Adversary Evasion	**Easy to Eade:** Attackers can easily recompile code (change hash) or shift IP addresses.	**Hard to Evade:** Adversaries cannot easily change core attack techniques (e.g., LSASS memory read).
Detection Tooling	Antivirus signatures, Firewall IP blocklists, Threat Intel feeds.	Endpoint Detection & Response (EDR), Behavioral SIEM correlation rules.

3. PRACTICAL EXAMPLE SCENARIOS

Malicious IP Addresses: Known C2 server IP address `198.51.100.45` stored in threat intel *(IOC)* vs. An internal host attempting rapid outbound connections to 50 unknown external IPs on non-standard ports *(IOA)*. **File Hashes:** SHA256 hash matching known WannaCry ransomware *(IOC)* vs. A process executing `vssadmin.exe delete shadows /all /quiet` to destroy system backup snapshots *(IOA)*. **Suspicious PowerShell Activity:** A file named `malicious_script.ps1` on disk *(IOC)* vs. PowerShell running an encoded string directly in memory using hidden parameters `-NoP -W Hidden -enc` *(IOA)*. **Unusual Login Behavior:** Login originating from a flagged TOR exit node IP *(IOC)* vs. Account `admin_user` logging into 15 internal workstations within 60 seconds (Impossible Travel / Mass Lateral Movement) *(IOA)*. **Network Scanning:** Nmap scan signature matching known tool headers *(IOC)* vs. A workstation attempting sequential TCP connections across all internal subnets over port 445 *(IOA)*.

4. HOW BOTH HELP SOC ANALYSTS

Complementary Defensive Value

IOCs enable rapid automated searching across historical SIEM logs to confirm if an enterprise was previously exposed to a known threat campaign.

IOAs empower Next-Gen EDR solutions to intercept zero-day attacks and fileless malware in real time by blocking dangerous behaviors before data destruction occurs.

5. TERMINOLOGY & REFERENCES

TTPs (Tactics, Techniques, and Procedures): The patterns of behavior or methods used by threat actors. **Zero-Day Attack:** An attack exploiting a previously unknown vulnerability before a signature (IOC) exists.

References:

• CrowdStrike Research - IOAs vs IOCs: **https://www.crowdstrike.com/**

• MITRE ATT&CK Framework Design Concepts: **https://attack.mitre.org/**